

Identity & Access Management

Wer bist du – und was
darfst du?

Agenda

- **IAM verstehen** – Geschäftliche Bedeutung und zentrale Begriffe
- **Identitäten steuern** – Vom Eintritt bis zum Austritt
- **Sicher anmelden** – Sicherheit und Nutzererlebnis ausbalancieren
- **Berechtigungen beherrschen** – Rollen, Kontrollen und Governance
- **IAM beraten** – Bedarf erkennen, Nutzen vermitteln, Einführung begleiten

IAM verstehen

Mehr als Login und Passwort

Was ist IAM?

- **Identity & Access Management (IAM):** Verwaltung digitaler Identitäten und ihrer Zugriffe
- Zwei Kernfragen:
 - **Wer bist du?** – Identität verlässlich feststellen
 - **Was darfst du?** – Zugriff passend zur Aufgabe steuern
- Gilt für Mitarbeitende, Partner, Kunden und technische Konten
- Verbindet **Menschen, Prozesse, Regeln und Systeme**

Merksatz: Die richtige Identität erhält den richtigen Zugriff – zur richtigen Zeit.

Analogie: Das Bürogebäude

Physische Welt

- Mitarbeiterausweis
- Empfang prüft Identität
- Zutritt nur zu erlaubten Bereichen
- Besucher werden protokolliert

Digitale Welt

- Digitales Benutzerkonto
- Anmeldung prüft Identität
- Zugriff nur auf erlaubte Daten
- Aktivitäten werden nachvollziehbar

Warum ist IAM ein Geschäftsthema?

- **Sicherheit:** Missbrauch von Konten und Daten begrenzen
- **Effizienz:** Zugänge schneller bereitstellen und entziehen
- **Compliance:** Vorgaben und Prüfungen nachvollziehbar erfüllen
- **Nutzererlebnis:** Weniger Anmeldehürden und Wartezeiten
- **Wachstum:** Neue Mitarbeitende, Partner und Cloud-Dienste integrieren

IAM beeinflusst Produktivität, Kundenerlebnis und Risikokosten zugleich.

Typische Auslöser für IAM-Projekte

- Prüfung beanstandet fehlende Zugriffsnachweise
- Ehemalige Mitarbeitende besitzen noch aktive Konten
- Rollenwechsel führt zu immer mehr Berechtigungen
- Viele Anwendungen erfordern eigene Anmeldungen
- Partnerzugänge werden per E-Mail und Excel verwaltet
- Kunden brechen Registrierung oder Anmeldung ab

Wer hat ein Interesse an IAM?

Stakeholder	Typisches Ziel
Geschäftsleitung	Risiken und Kosten kontrollieren
Fachbereiche	Schneller arbeitsfähig sein
Personalbereich	Ein- und Austritte zuverlässig abbilden
IT & Sicherheit	Konten zentral und sicher steuern
Revision & Compliance	Entscheidungen nachweisen können
Kunden & Partner	Einfacher, verlässlicher Zugang

Drei Perspektiven ausbalancieren

Zu wenig Kontrolle

- Unklare Verantwortungen
- Übermäßige Zugriffe
- Hohe Schadenswirkung

Zu viel Reibung

- Langsame Freigaben
- Umgehungslösungen
- Schlechte Nutzererfahrung

Ziel: Angemessene Kontrolle statt maximaler Kontrolle.

IAM als Prozesskette

1. Identität entsteht oder wird erfasst
2. Rolle und Bedarf werden bestimmt
3. Zugriff wird beantragt und genehmigt
4. Nutzung wird überwacht und überprüft
5. Zugriff wird angepasst oder beendet

Schwachstellen entstehen häufig an den **Übergaben** zwischen Bereichen.

Identitäten steuern

Vom Eintritt bis zum Austritt

Was ist eine digitale Identität?

- Digitale Repräsentation einer Person, Organisation oder eines Systems
- Besteht aus **Merkmale**n wie Name, Kundennummer, Abteilung oder Rolle
- Kann mehrere Konten in verschiedenen Anwendungen umfassen
- Benötigt einen klaren Eigentümer und verlässliche Datenquelle

Eine Person kann mehrere Konten besitzen – aber nur eine fachliche Identität.

Nicht nur Mitarbeitende

Identitätsgruppe	Beispiel	Besondere Frage
Mitarbeitende	Festangestellte	Welche Aufgabe und Rolle?
Externe	Beratung, Zeitarbeit	Wer verantwortet Laufzeit und Zugriff?
Partner	Lieferanten, Händler	Welche Organisationsgrenzen gelten?
Kunden	Portal- oder App-Nutzer	Wie einfach darf Registrierung sein?
Technische Identitäten	Dienste, Geräte	Wer ist fachlich verantwortlich?

Der Identitätslebenszyklus

- **Joiner:** Eintritt oder erstmalige Registrierung
- **Mover:** Wechsel von Rolle, Bereich oder Aufgabe
- **Leaver:** Austritt oder Ende einer Geschäftsbeziehung
- **Review:** Regelmäßige Prüfung bestehender Zugriffe

Änderungen sind der Normalfall – IAM muss sie zuverlässig begleiten.

Joiner: Schnell und kontrolliert starten

- Stammdaten rechtzeitig und korrekt erfassen
- Standardzugänge aus Funktion und Standort ableiten
- Zusätzliche Rechte bewusst genehmigen
- Startdatum und Vertragsart berücksichtigen
- Arbeitsfähigkeit am ersten Tag sicherstellen

Mover: Rechte folgen der Aufgabe

- Neue Aufgabe erfordert neue Zugriffe
- Alte Rechte aktiv prüfen und entfernen
- Befristete Zusatzrechte automatisch beenden
- Funktionstrennung weiterhin sicherstellen
- Wechsel als vollständigen Prozess behandeln

Privilege Creep: Rechte wachsen über die Zeit, obwohl der Bedarf entfällt.

Leaver: Zugriffe sicher beenden

- Austrittszeitpunkt eindeutig festlegen
- Konten und aktive Sitzungen rechtzeitig sperren
- Geräte, Schlüssel und geteilte Zugänge berücksichtigen
- Daten und Aufgaben geordnet übergeben
- Ausnahmen dokumentieren und befristen

Wer ist wofür verantwortlich?

Verantwortung	Typischer Eigentümer
Beschäftigungsstatus	Personalbereich
Fachlicher Zugriffsbedarf	Führungskraft / Fachbereich
Schutzbedarf einer Anwendung	Anwendungseigentümer
Technische Bereitstellung	IT-Betrieb
Regelwerk und Kontrolle	Informationssicherheit / Compliance

Die verlässliche Datenquelle

- Eintritt, Wechsel und Austritt benötigen ein **führendes Signal**
- Häufige Quelle: Personal- oder Partnersystem
- Datenqualität bestimmt die Qualität der Automatisierung
- Unklare IDs und verspätete Meldungen erzeugen Fehler
- Sonderfälle brauchen definierte Verfahren

Schlechte Eingangsdaten werden durch Automatisierung nur schneller verteilt.

Fallbeispiel: Wechsel in den Vertrieb

- Mitarbeiter wechselt aus dem Einkauf in den Vertrieb
- Benötigt neu: CRM, Preislisten, Kundenkontakte
- Benötigt nicht mehr: Lieferantenbewertung, Bestellfreigaben
- Kritisch: Einkauf und Verkauf nicht unkontrolliert kombinieren
- Ziel: Änderung pünktlich, vollständig und nachweisbar

Reifegrad des Identitätsmanagements

Stufe	Kennzeichen
Reaktiv	Einzelne Konten, manuelle Zurufe
Standardisiert	Dokumentierte Abläufe und Zuständigkeiten
Integriert	Führende Datenquellen und verbundene Systeme
Automatisiert	Regelbasierte Bereitstellung und Entzug
Gesteuert	Kennzahlen, Reviews und kontinuierliche Verbesserung

Sicher anmelden

Sicherheit und Nutzererlebnis verbinden

Authentifizierung und Autorisierung

Authentifizierung: Ist die Person wirklich, wer sie vorgibt zu sein?

Autorisierung: Was darf diese bestätigte Identität tun?

Die Schritte gehören zusammen, erfüllen aber verschiedene Zwecke

Reisepass bestätigt die Person – Bordkarte bestimmt Flug und Sitzplatz.

Drei Arten von Nachweisen

Faktor	Leitfrage	Beispiele
Wissen	Was weißt du?	Passwort, PIN
Besitz	Was hast du?	Smartphone, Sicherheitsschlüssel
Sein	Was bist du?	Fingerabdruck, Gesicht

- Kombination unterschiedlicher Faktoren erhöht die Sicherheit
- Zwei Passwörter bleiben nur **ein** Faktor

Passwortstärke und Entropie

- **Entropie:** Maß für die Unvorhersehbarkeit, angegeben in Bit
- Für zufällige Zeichen gilt näherungsweise:

$$E = L \times \log_2(R)$$

- L : Passwortlänge, R : Größe des verwendeten Zeichenraums
- Mehr mögliche Kombinationen → mehr Aufwand zum Durchprobieren
- Gilt nur bei **wirklich zufälliger** Auswahl

Unternehmen2026! ist lang, aber wegen des Musters leicht vorhersagbar.

Länge schlägt bloße Komplexität

Beispiel	Zeichen	Grobe Einordnung
P@u12026!	9	Muster und persönliche Bezüge
KaffeeMontagBüro	16	lang, aber sprachlich vorhersagbar
Vier zufällige Wörter	ca. 20–30	lang und gut merkbar
Manager-generiertes Passwort	20+	lang, zufällig und einzigartig

- Für jeden Dienst ein **einzigartiges** Passwort verwenden
- Passwort-Manager verhindern Wiederverwendung
- **Online-Angriff:** Anmeldesperren begrenzen Versuche
- **Offline-Angriff:** Gestohlene Passwortdaten erlauben sehr viele Versuche

Wie Angreifer Passwörter überwinden

Angriff	Prinzip	Wichtigste Gegenmaßnahme
Brute Force	Kombinationen durchprobieren	Länge, Begrenzung der Versuche
Wörterbuchangriff	Häufige Wörter und Muster testen	Zufällige Passwörter / Passphrasen
Credential Stuffing	Geleakte Passwörter wiederverwenden	Einzigartiges Passwort je Dienst
Phishing	Menschen zur Eingabe verleiten	MFA, Passkeys, Sensibilisierung

Passwortstärke hilft gegen Erraten – nicht gegen jede Form des Diebstahls.

Multi-Faktor-Authentifizierung

- **Multi-Faktor-Authentifizierung (MFA):** mindestens zwei unterschiedliche Nachweise
- Begrenzt Schäden durch gestohlene Passwörter
- Besonders wichtig für:
 - Externe Zugriffe
 - Administrationskonten
 - Kritische Anwendungen
 - Ungewöhnliche Anmeldesituationen

MFA aus Geschäftssicht bewerten

Kriterium	Leitfrage
Schutzwirkung	Welche Angriffe werden verhindert?
Nutzererlebnis	Wie häufig und wie einfach erfolgt die Bestätigung?
Reichweite	Welche Nutzer und Geräte werden unterstützt?
Betrieb	Wie funktionieren Ausgabe, Wechsel und Sperrung?
Wiederherstellung	Was geschieht bei Verlust?
Kosten	Welche Einführungs- und Supportkosten entstehen?

MFA erfolgreich einführen

- Betroffene Gruppen und Risiken priorisieren
- Einfache Registrierung und verständliche Kommunikation
- Pilotgruppe vor breitem Rollout
- Ersatz- und Notfallverfahren vorab definieren
- Support auf typische Probleme vorbereiten
- Nutzung und Abbruchquoten beobachten

Passkeys: Das Konzept

- Anmeldung ohne klassisches Passwort
- Gerät weist die Identität gegenüber dem richtigen Dienst nach
- Biometrie oder Geräte-PIN bestätigt lokal die Nutzung
- Kein wiederverwendbares Passwort, das preisgegeben werden kann
- Ziel: höhere Sicherheit bei weniger Reibung

Passkeys: Nutzen und offene Fragen

Potenzial

- Weniger Phishing-Erfolg
- Weniger Passwort-Support
- Schnelle Anmeldung
- Gute mobile Nutzung

Zu klären

- Geräteverlust
- Plattformwechsel
- Gemeinsame Geräte
- Akzeptanz und Support

Single Sign-On

- **Single Sign-On (SSO):** einmal anmelden, mehrere Anwendungen nutzen
- Zentraler **Identity Provider (IdP)** bestätigt die Anmeldung
- Vorteile:
 - Weniger Anmeldungen und Passwörter
 - Zentrale Durchsetzung von MFA
 - Schnellere Sperrung bei Austritt
 - Einheitlicheres Nutzererlebnis
- Zentraler Zugang benötigt besonders starken Schutz

SSO: Vereinfachter Vertrauensfluss

1. Nutzer öffnet eine angebundene Anwendung
2. Anwendung verweist zur Anmeldung an den **IdP**
3. IdP prüft Identität, bei Bedarf mit MFA
4. IdP stellt einen zeitlich begrenzten Nachweis aus
5. Anwendung prüft den Nachweis und gewährt Zugriff

Die Anwendung erhält normalerweise **nicht** das Passwort.

SSO-Standards verständlich eingeordnet

Standard	Typischer Einsatz	Vereinfacht gesagt
SAML 2.0	Unternehmens- und ältere Webanwendungen	XML-basierter Anmeldenachweis
OpenID Connect (OIDC)	Moderne Web- und Mobile-Apps	Identitätsschicht auf OAuth 2.0
OAuth 2.0	Delegierter Zugriff auf Daten	Autorisierung, nicht allein Anmeldung

- Standard bestimmt den Austausch – nicht automatisch die Qualität des Gesamtkonzepts

Anmeldung als Teil der Customer Journey

- Registrierung nur mit notwendigen Angaben
- Verständliche Identitätsprüfung passend zum Risiko
- Wenige, klare Schritte bei der Anmeldung
- Transparente Fehlermeldungen und Wiederherstellung
- Schrittweise stärkere Prüfung bei sensiblen Aktionen

Nicht jeder Klick benötigt dieselbe Vertrauensstufe.

Berechtigungen beherrschen

Rollen, Kontrollen und Governance

Prinzip der geringsten Rechte

- Nur Zugriffe vergeben, die für die Aufgabe nötig sind
- Umfang und Dauer auf den Bedarf begrenzen
- Besonders mächtige Rechte gesondert behandeln
- Nicht mehr benötigte Zugriffe zeitnah entfernen

Leitfrage: Was ist notwendig – nicht, was könnte irgendwann nützlich sein?

Rollen statt Einzelrechte

- **Role-Based Access Control (RBAC):** Rechte werden zu fachlichen Rollen gebündelt
- Beispiele: Vertriebsmitarbeiter, Teamleitung, Buchhaltung
- Vorteile:
 - Verständlich für Fachbereiche
 - Schnellere Zuordnung
 - Einheitlichere Rechte
- Risiko: Zu viele oder zu breite Rollen

Kontextabhängige Entscheidungen

- Rolle allein beantwortet nicht jede Zugriffssituation
- Zusätzliche Merkmale können berücksichtigt werden:
 - Standort oder Land
 - Verwaltetes oder privates Gerät
 - Arbeitszeit oder ungewöhnliches Verhalten
 - Schutzbedarf der angefragten Daten
- Mehr Flexibilität bedeutet mehr Erklärungs- und Pflegeaufwand

Funktionstrennung

- **Segregation of Duties (SoD):** Kritische Schritte auf mehrere Personen verteilen
- Verhindert alleinige Kontrolle über einen vollständigen Vorgang
- Beispiele:
 - Bestellung anlegen und Zahlung freigeben
 - Lieferant anlegen und Bankdaten ändern
 - Rabatt erfassen und selbst genehmigen

Genehmigungen sinnvoll gestalten

- Genehmiger muss den fachlichen Bedarf beurteilen können
- Kritische Rechte benötigen stärkere Kontrolle
- Standardrollen möglichst effizient zuweisen
- Begründung, Entscheidung und Laufzeit dokumentieren
- Eskalation bei ausbleibender Entscheidung vorsehen

Regelmäßige Überprüfung

- Verantwortliche bestätigen oder entziehen bestehende Zugriffe
- Fokus auf kritische Systeme und auffällige Rechte
- Verständliche Darstellung statt technischer Bezeichnungen
- Entscheidungen und Fristen nachvollziehbar dokumentieren
- Ergebnisse zur Verbesserung von Rollen nutzen

Privilegierte Zugriffe

- Administratoren und Notfallkonten besitzen besonders hohe Wirkung
- **Privileged Access Management (PAM)** schützt diese Zugriffe gezielt
- Typische Konzepte:
 - Rechte nur bei Bedarf und zeitlich begrenzt
 - Zusätzliche Genehmigung oder MFA
 - Nachvollziehbare Nutzung
 - Sichere Notfallverfahren

Governance schafft Verbindlichkeit

- Klare Richtlinien und Geltungsbereiche
- Benannte Eigentümer für Rollen, Anwendungen und Daten
- Definierte Ausnahmen mit Ablaufdatum
- Messbare Kontrollen und regelmäßige Berichte
- Konsequente Verbesserung aus Vorfällen und Reviews

Kennzahlen für die Steuerung

Ziel	Beispielkennzahl
Schneller Start	Zeit bis zur Arbeitsfähigkeit
Sicherer Austritt	Zeit bis zur vollständigen Sperrung
Weniger Altlasten	Anteil entzogener Rechte in Reviews
Starke Anmeldung	MFA-Abdeckung kritischer Konten
Gute Erfahrung	Anmeldeabbrüche und Supportfälle
Automatisierung	Anteil automatisch bereitgestellter Zugriffe

IAM beraten

Vom Bedarf zum tragfähigen Zielbild

Mit dem Problem beginnen

- Welches Geschäftsziel soll unterstützt werden?
- Wo entstehen heute Risiken, Kosten oder Verzögerungen?
- Welche Nutzergruppen und Anwendungen sind betroffen?
- Welche Vorgaben und Fristen gelten?
- Woran würde der Kunde eine Verbesserung erkennen?

Discovery: Beobachtbare Warnsignale

- Konten werden per E-Mail oder Ticket einzeln angelegt
- Excel-Listen dienen als zentrale Berechtigungsübersicht
- Niemand fühlt sich für externe Zugänge verantwortlich
- Audits führen regelmäßig zu kurzfristigen Aufräumaktionen
- Passwort- und Zugriffsprobleme dominieren den Support
- Neue Anwendungen werden ohne gemeinsames Identitätskonzept eingeführt

Anforderungen aus mehreren Blickwinkeln

Blickwinkel	Beispielanforderung
Geschäft	Neue Mitarbeitende am ersten Tag arbeitsfähig
Sicherheit	Kritische Zugriffe mit MFA schützen
Compliance	Genehmigungen lückenlos nachweisen
Nutzer	Einfache Anmeldung und Wiederherstellung
Betrieb	Standardfälle automatisiert verarbeiten
Architektur	Bestehende Anwendungen schrittweise anbinden

Vom Ist-Zustand zum Zielbild

1. Prozesse, Identitätsgruppen und Anwendungen erfassen
2. Risiken, Engpässe und Abhängigkeiten bewerten
3. Zielprozesse und Verantwortungen definieren
4. Benötigte Fähigkeiten und Integrationen ableiten
5. Maßnahmen nach Nutzen und Machbarkeit priorisieren

Nutzen verständlich formulieren

Funktion	Geschäftlicher Nutzen
Automatisierter Joiner	Schnellere Produktivität, weniger Tickets
Automatisierter Leaver	Kürzere Risikodauer nach Austritt
SSO	Weniger Reibung und Passwortaufwand
MFA	Weniger erfolgreiche Kontoübernahmen
Rollenmodell	Einheitlichere, verständliche Vergabe
Reviews	Nachweisbare Kontrolle und weniger Altlasten

Business Case für IAM

- **Direkte Kosten:** Lizenzen, Einführung, Integration, Betrieb
- **Effizienzgewinne:** weniger manuelle Bearbeitung und Support
- **Risikoreduktion:** geringere Wahrscheinlichkeit oder Auswirkung von Vorfällen
- **Compliance-Nutzen:** weniger Prüfungsaufwand und Feststellungen
- **Geschäftsnutzen:** schnellere Skalierung und bessere Nutzererfahrung

Eine realistische Roadmap

- **Phase 1 – Fundament:** Verantwortungen, Daten, Kernprozesse
- **Phase 2 – Quick Wins:** SSO, MFA, priorisierte Anwendungen
- **Phase 3 – Automatisierung:** Joiner, Mover, Leaver
- **Phase 4 – Governance:** Rollen, Reviews, Kennzahlen
- **Phase 5 – Ausbau:** Partner, Kunden, technische Identitäten

Früh Nutzen zeigen, ohne das langfristige Zielbild zu verlieren.

Häufige Stolpersteine

- Produkt gekauft, bevor Prozesse geklärt sind
- IAM als reines IT-Projekt behandelt
- Datenqualität und Altanwendungen unterschätzt
- Zu großes Zielbild ohne priorisierte Etappen
- Nutzerkommunikation und Support zu spät geplant
- Rollen und Regeln nach Projektende nicht gepflegt

Gute Verkaufsfragen

- Wie lange dauert es, bis neue Mitarbeitende arbeitsfähig sind?
- Wie sicher sind alle Zugriffe am Austrittstag beendet?
- Wer kann heute erklären, warum eine Person ein Recht besitzt?
- Welche Anmeldung verursacht die meisten Beschwerden?
- Wie viel Aufwand entsteht für Prüfungen und Nachweise?
- Welche Wachstumspläne scheitern an manuellen Zugangsprozessen?

Erfolg eines IAM-Projekts

- Fachbereiche übernehmen Verantwortung für Rollen und Zugriffe
- Nutzer erhalten benötigte Zugänge schneller
- Nicht mehr benötigte Rechte verschwinden zuverlässig
- Kritische Konten sind angemessen geschützt
- Prüfungen können Entscheidungen nachvollziehen
- Kennzahlen zeigen Wirkung und Verbesserungsbedarf

Zusammenfassung

Thema	Kernaussage
Geschäftswert	IAM verbindet Sicherheit, Effizienz und Nutzererlebnis
Lebenszyklus	Zugriffe müssen Eintritt, Wechsel und Austritt folgen
Anmeldung	Starke Passwörter, MFA und SSO passend kombinieren
Berechtigungen	Fachliche Rollen, geringste Rechte und Reviews schaffen Kontrolle
Beratung	Problem, Zielbild und Nutzen kommen vor der Produktauswahl
Einführung	Schrittweise vorgehen und Wirkung mit Kennzahlen steuern

Diskussionsfragen

- Wo erlebt ihr selbst unnötige Hürden bei Registrierung oder Anmeldung?
- Welche IAM-Probleme lassen sich organisatorisch lösen – ganz ohne neues Produkt?
- Wann sollte Nutzerkomfort zugunsten höherer Sicherheit eingeschränkt werden?
- Welche Kennzahl überzeugt Geschäftsleitung, Fachbereich und Revision gleichermaßen?
- Mit welchem Anwendungsfall würdet ihr bei der Mini-Fallstudie beginnen?